

Curso de Especialización Ciberseguridad en las TIC

Práctica 2. Autenticación basada en características biométricas

Objetivos

- Diseñar una combinación de mecanismos de autenticación.
- Describir el protocolo utilizado y la política de autenticación utilizada-
- Implementar el reconocimiento biométrico como mecanismos de autenticación en un equipo Windows 11 y GNU/Linux.

Resumen

Autora: Marina del Pilar López Oliva

Diciembre 2025

IES Camp de Morvedre

Obra publicada con [Licencia Creative Commons Reconocimiento Compartir igual 4.0](https://creativecommons.org/licenses/by-sa/4.0/)



Revisión

Revisión	Fecha	Descripción
1.0	03/12/2025	Configuración de la plantilla.
1.1	05/12/2025	Realización de la práctica.
1.2	07/12/2025	Finalización de la documentación y revisión de la práctica.

Índice de Contenidos

1. Introducción.....	4
2. RA2.a.....	4
3. RA2.e.....	5
4. Conclusión.....	11
5. Webgrafía.....	11

1. Introducción

En esta práctica vamos a diseñar un sistema de autenticación basado en múltiples factores. Así sustituiremos las credenciales tradicionales por métodos biométricos en equipos Windows y Linux. Implementaremos un esquema de autenticación en dos fases, combinando una credencial de usuario con un factor inherente biométrico.

El documento se dividirá en dos apartados. En el primero de ellos, diseñaremos una combinación de mecanismos de autenticación en el marco del subsistema de nuestro proyecto. El diseño deberá contemplar al menos el uso de un factor inherente (huella dactilar, escaneo del iris o facial). En el segundo realizaremos la descripción del protocolo utilizada y la política de autenticación utilizada identificando la fortificación que se alcanza ante las vulnerabilidades y tipos de ataques posibles en el contexto de la práctica. Además, se incluirá una explicación de la puesta en práctica de los mismos.

2. RA2.a

Antes de empezar con la implementación, hemos definido un diseño que reforzará el modelo de acceso actual. Este diseño reemplazará el tipo de credenciales que se tiene actualmente en uso por una autenticación segura en dos fases. Este sistema asocia al usuario una credencial de conocimiento (contraseña) y un factor inherente biométrico vinculado al equipo.

El subsistema de usuarios estará compuesto por dos equipos clientes con dos entornos operativos: Windows 11 unido al dominio del subsistema y GNU/Linux. El modelo de acceso actual se basa en usuario y contraseña, lo que representa un punto débil en términos de seguridad.

Para reemplazar las credenciales tradicionales y cumplir con los requisitos de una autenticación seguros en dos fases, podemos utilizar los siguientes factores:

- **Factor inherente (biométrico):** Windows 11 utilizará el reconocimiento facial mediante Windows Hello. En Linux se implementará reconocimiento facial mediante Howdy, integrado con PAM. Esta elección se justifica por la uniformidad, higiene y accesibilidad en un entorno educativo, donde los equipos suelen contar con cámara pero no con lector de huellas.

- **Factor de conocimiento:** contraseña robusta del usuario, gestionada desde el directorio centralizado.

El diseño implementa una autenticación en dos fases que sustituye por completo el inicio de sesión por usuario y contraseña.

- **Autenticación por conocimiento.** El usuario introduce su nombre de usuario y contraseña.
- **Autenticación biométrica (factor inherente).** Tras validar las credenciales, se activa el sensor facial para verificar la identidad del usuario localmente en el equipo.

3. RA2.e

Ahora que el diseño está hecho, podemos realizar el siguiente apartado. Aquí, vamos a describir los protocolos utilizados, las políticas, la fortificación ante ataques, y la puesta en práctica del diseño.

Vamos a definir un sistema de autenticación multifactor en dos fases, aplicable tanto a Windows 11 como a Ubuntu. Sustituyendo así el acceso tradicional basado únicamente en usuario y contraseña.

- **Políticas de autenticación:**
 - Requisito obligatorio de MFA: inicio de sesión realizado mediante la combinación de un factor inherente y un factor de conocimiento.
 - Privacidad y custodia de las plantillas biométricas:
 - En Windows 11, la plantilla facial se almacena en el equipo, con cifrado basado en TPM 2.0. No llega a enviarse nunca al controlador del dominio.
 - En Linux, Howdy almacena los datos faciales de forma local y cifrada, sin transmisión por red ni sincronización con el dominio.
 - Frecuencia de autenticación: se exige autenticar en cada inicio o desbloqueo de sesión.
 - Sustitución del método tradicional: se mantiene el acceso por contraseña como primer factor, reforzada con biométrica facial como segundo factor obligatorio.

- **Protocolos de acceso:** el protocolo de autenticación sigue una secuencia de dos fases. El usuario introduce las credenciales en el equipo cliente. El sistema valida las credenciales con el servidor de directorio. Tras la validación exitosa, se activa el sensor facial:
 - En Windows, se solicita un Ticket Kerberos al controlador de dominio.
 - En Linux, se utiliza PAM junto con SSSD para complementar la autenticación.
- **Fortificación ante vulnerabilidades y tipos de ataques:**

Vulnerabilidades Ataques	Fortificación que aporta el sistema implantado
Fuerza bruta	Aunque la contraseña puede ser vulnerada, el atacante necesitaría además la característica biométrica única del usuario.
Phishing Keylogging	Un atacante de phishing puede capturar la contraseña, pero no puede replicar la biometría facial del usuario mediante estos métodos.
Ataques de prestación	Windows Hello y Howdy incluyen detección de vida (anti-spoofing) con cámara IR/RGB, previniendo uso de fotos o máscaras.
Ataques de replay del código TOTP	La biometría es un factor no replicable en el tiempo. Una sesión biométrica no puede reutilizarse.
Suplantación por deepfake	Los algoritmos de detección de vida y los sensores certificados previenen la validación de rostros sintéticos.
Robo o pérdida del dispositivo	El equipo por sí solo no basta: se necesita la contraseña y la biometría del usuario legítimo.

Compromiso de la base de datos	Las plantillas biométricas no se almacenan en los servidores de directorio. Solo localmente en el equipo.
--------------------------------	---

Figura 1. Fortificación que se alcanza ante las vulnerabilidades y tipos de ataques posibles.

Hemos seleccionado la implementación de reconocimiento facial en ambos sistemas por:

- **Uniformidad y facilidad de uso:** misma experiencia en todos los equipos.
- **Higiene y no contacto:** importante en entornos compartidos como aulas y laboratorios.
- **Hardware accesible:** la cámara es un componente normalmente estándar en equipos modernos.
- **Seguridad mejorada:** tecnologías anti-spoofing integradas con Windows Hello y Howdy.
- **Cumplimiento normativo:** los datos biométricos se almacenan localmente, cumpliendo con RGPD y normativas de privacidad.

Una vez diseñado y explicado por qué hemos elegido cada aspecto, vamos a realizar la implementación en cada uno de los equipos.

Empezamos con Windows 11, ya que será más fácil implementarlo, teniendo en cuenta que Windows Hello viene por defecto en los equipos. Antes de nada, deberíamos meterlo en el Active Directory del dominio. A continuación, deberemos encender el ordenador como el usuario que queramos. Nos dirigimos a la configuración, y ahí buscamos Windows Hello para configurarlo.

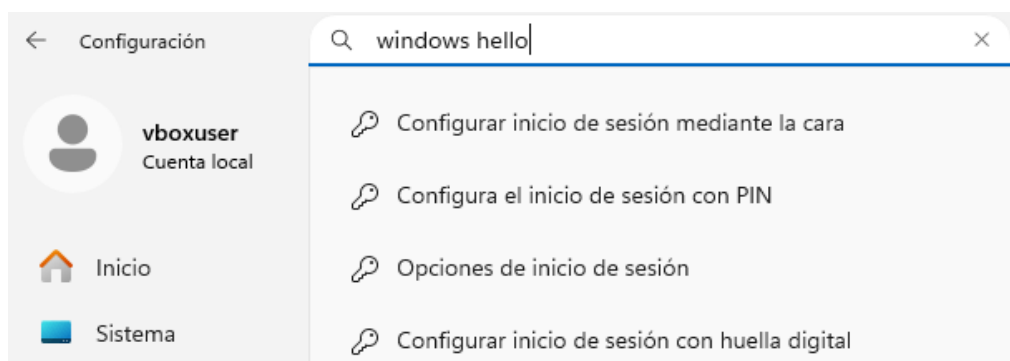


Figura 2. Configuración del equipo Windows 11.

Como vemos, se nos muestran todas las configuraciones que tenemos disponibles con Windows Hello. Seleccionamos configurar el inicio de sesión mediante la cara. Ya que queremos que los equipos cuenten con reconocimiento facial.

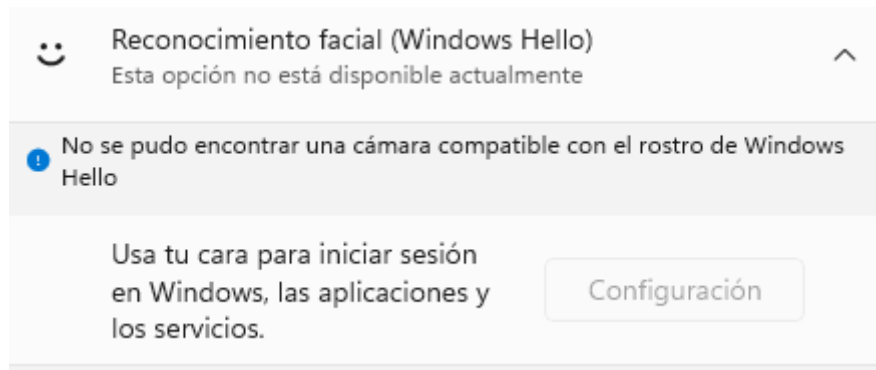


Figura 3. Configuración del reconocimiento facial mediante Windows Hello.

En este caso es una simulación y no contamos con una cámara para activar Windows Hello. Sin embargo, si estuviéramos en un entorno real, deberíamos entrar en “Configuración” y seguir las instrucciones para completar la configuración de Windows Hello. Hay que verificar que la opción “Requerir inicio de sesión con Windows Hello” esté activada. El usuario puede iniciar sesión ahora combinando contraseña y reconocimiento facial, cumpliendo con el esquema de autenticación en dos fases propuesto anteriormente.

A continuación, vamos a realizar la misma configuración para los equipos Linux. Hemos utilizado howdy ya que equivale al Windows Hello, y sirve para la autenticación facial de las personas. En un entorno real, se requeriría de una cámara web funcional. Los siguientes pasos se han realizado en una máquina virtual, simulando la configuración hasta dónde hemos conseguido. El resto se explica de manera teórica.

Lo primero que tenemos que hacer es instalar Howdy. Para instalar Howdy necesitamos una cámara. Primero vamos a añadir el repositorio de Howdy desde el PPA oficial.

```
ubuntu@ubuntu2204:~$ sudo add-apt-repository ppa:boltgolt/howdy
Repository: 'Types: deb
URIs: https://ppa.launchpadcontent.net/boltgolt/howdy/ubuntu/
Suites: noble
```

Figura 4. Adición del PPA oficial de Howdy para su instalación.

A continuación, instalamos el programa de autenticación facial después de actualizar el sistema.

```
ubuntu@ubuntu2204:~$ sudo apt update
Hit:1 http://in.archive.ubuntu.com/ubuntu noble InRelease
Hit:2 https://ppa.launchpadcontent.net/boltgolt/howdy/ubuntu noble InRelease
Hit:3 http://in.archive.ubuntu.com/ubuntu noble-updates InRelease
Hit:4 http://in.archive.ubuntu.com/ubuntu noble-backports InRelease
Hit:5 http://security.ubuntu.com/ubuntu noble-security InRelease
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
605 packages can be upgraded. Run 'apt list --upgradable' to see them.
ubuntu@ubuntu2204:~$ sudo apt install howdy
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
```

Figura 5. Instalación de Howdy desde el PPA oficial.

En el modo de configuración cuando se instala, tendríamos que seleccionar el seguro para que sea de una forma más segura a la manera de autenticar la cara. Sin embargo, es posible que en algunos centros se utilice el rápido o el balanceado para una seguridad con rapidez de reconocimiento.

```
F: Fast.
Allows more fuzzy matches, but speeds up the scanning process greatly.

B: Balanced.
Still relatively quick detection, but might not log you in when further away.

S: Secure.
The safest option, but will take much longer to authenticate you.

You can always change this setting in the config.
What profile would you like to use? [f/b/s]:
```

Figura 6. Elección de seguridad de la autenticación mediante Howdy.

Tendremos que comprobar la ubicación del dispositivo de nuestra cámara. Las cámaras suelen estar almacenadas en `/dev/video*` teniendo cada cámara un número identificativo.

```
ubuntu@ubuntu2204:~$ ls -l /dev/video*  
crw-rw-rw-+ 1 root video 81, 0 Dec  5 13:39 /dev/video0
```

Figura 7. Identificación de nuestra supuesta cámara.

Esta cámara está simulada, es decir, no contamos con una cámara real.

Ahora editamos el archivo de configuración para apuntar a nuestra cámara. Para ello, nos vamos al archivo de configuración de Howdy y añadimos la línea correspondiente.

```
GNU nano 7.2 /etc/howdy/config.ini *  
device_path = /dev/video0
```

Figura 8. Archivo de configuración de Howdy apuntando a la cámara.

Añadiríamos un nuevo rostro con “sudo howdy add” o si queremos que sea un usuario específico usaremos, por ejemplo “sudo howdy add -u profesor-1”.

Para seguir, deberemos integrarlo con PAM. Para ello, iremos a /etc/pam.d/common-auth y añadiremos la línea “auth suficiente pam_python.so (...)”, así Howdy intenta autenticar antes de pedir la contraseña.

```
GNU nano 7.2 /etc/pam.d/common-auth *  
# As of pam 1.0.1-6, this file is managed by pam-auth-update by default.  
# To take advantage of this, it is recommended that you configure any  
# local modules either before or after the default block, and use  
# pam-auth-update to manage selection of other modules. See  
# pam-auth-update(8) for details.  
  
# here are the per-package modules (the "Primary" block)  
auth    sufficient          pam_python.so /lib/security/howdy/pam.py  
auth    [success=2 default=ignore] pam_unix.so nullok
```

Figura 9. Configuración de PAM con Howdy.

Para probar si funciona la autenticación correctamente podríamos utilizar “sudo -v”. Para ver los registros de eventos de Howdy se puede utilizar “sudo tail -f /var/log/auth.log | grep howdy”.

Aunque no podemos mostrar el funcionamiento, con esta configuración hemos hecho que se puedan autenticar con reconocimiento facial. Primero el usuario introduce su nombre. Después, Howdy activa la cámara y espera el reconocimiento facial. A continuación se compara el rostro con el modelo almacenado y si coincide se inicia sesión. Si falla, nos pide contraseña.

4. Conclusión

Hemos implementado un 2FA en el subsistema que nos tocó, en este caso, IES Camp de Morvedre. Combinamos las credenciales que ya se tenía configuradas, con reconocimiento facial. Teniendo en cuenta las características necesarias de un centro de educación. Además, se han valorado los distintos métodos de autenticación inherente, y se ha llegado a la conclusión que el reconocimiento facial es el más adecuado para nuestro subsistema.

Esta práctica nos enseña que los métodos de autenticación biométrica, como el reconocimiento facial, son alternativas efectivas y seguras a las contraseñas tradicionales. Al configurar Windows Hello y Howdy, comprobamos que se ofrece un sistema de protección robusto para datos biométricos. Además, no solo nos reducen los ataques basados en contraseñas, sino que nos mejora la seguridad general en entornos empresariales como los centros escolares.

5. Webgrafía

“Protocolos de autenticación biométrica.” Available: <https://fastercapital.com/es/tema/protocolos-de-autenticaci%C3%B3n-biom%C3%A9trica.html> . [Accessed: Dec. 03, 2025]

paolomatarazzo, “Windows Hello for Business overview.” Available: <https://learn.microsoft.com/en-us/windows/security/identity-protection/hello-for-business/> . [Accessed: Dec. 03, 2025]

How to use fringerprint for login in ubuntu. Available: <https://askubuntu.com/questions/1418229/how-to-use-fingerprint-for-login-in-ubuntu-22-04> . [Accessed: Dec. 03, 2025]

P. Grassi et al., “Digital Identity Guidelines: Authentication and Lifecycle Management,” National Institute of Standards and Technology, NIST Special Publication (SP) 800-63B (Withdrawn), Mar. 2020. doi: 10.6028/NIST.SP.800-63b. Available: <https://csrc.nist.gov/pubs/sp/800/63/b/upd2/final> . [Accessed: Dec. 03, 2025]

“OWASP Top Ten | OWASP Foundation.” Available: <https://owasp.org/www-project-top-ten/> . [Accessed: Dec. 03, 2025]

"Art. 9 GDPR – Processing of special categories of personal data," *General Data Protection Regulation (GDPR)*. Available: <https://gdpr-info.eu/art-9-gdpr/>. [Accessed: Dec. 03, 2025]